SPIKA TECH™

PROCEDIMIENTO DE GESTIÓN Y NOTIFICACIÓN DE INCIDENTES DE SEGURIDAD

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025 con	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 5
2 ALCANCE 5
3 DEFINICIONES Y ACRÓNIMOS 5
4 ROLES Y RESPONSABILIDADES 6
4.1 Responsable de SGSI 6
4.2 Usuario de SI de SPIKA TECH 6
4.3 Personal TI de SPIKA TECH 6
4.4 Responsable del Sistema de Información 6
4.5 Responsable de la Información y Responsable del Servicio 6
4.6 Responsable de Seguridad de la Información 7
4.7 Responsable del Tratamiento de Datos Personales 7
5 MODELO PARA LA GESTIÓN DE INCIDENTES 7
5.1 Preparación 8
5.1.1 Introducción 8
5.1.2 Fase aplicada a SPIKA TECH 9
5.2 Detección, análisis e identificación 9
5.2.1 Introducción 9
5.2.2 Fase aplicada a SPIKA TECH 10
5.3 Contención, mitigación y recuperación 11
5.3.1 Introducción 11
5.3.2 Fase aplicada a SPIKA TECH 11
5.4 Actividades posts-incidentes 13
5.4.1 Introducción 13
5.4.2 Fase aplicada a SPIKA TECH 14
6 NOTIFICACIÓN DE LOS INCIDENTES DE SEGURIDAD O CIBERINCIDENTES. 14
6.1 Notificación de incidentes de seguridad externa 15
6.2 Notificación de incidente de seguridad externa 16
7 BRECHAS DE SEGURIDAD (datos personales) 16
7.1 Clasificación Brechas de Seguridad 16
7.2 Nivel de riesgo (peligrosidad) 16
7.2.1 Notificación brechas de seguridad (datos personales) 17
8 Referencias 18

9 ANEXO 1 TIPOS de incidentes 20
10 ANEXO 2 Determinación del Nivel de Impacto de los Incidentes 22
11 ANEXO 3 Valoración brecha de seguridad (datos personales) 24
12 AnEXO 4 CONTENIDO COMUNICACIÓN (informativo) 27

1 OBJETIVO

Los incidentes de seguridad son situaciones que pueden causar un gran daño en nuestro entorno (sistemas de información, personas, reputación, negocios entre otros); por este motivo es importante tener la capacidad, en primer lugar, de prevenirlos, y en segundo, de detectarlos y de responder adecuadamente a ellos.

Entre tales requisitos, se distinguen que:

- Se establecerá un sistema de detección y reacción frente a código dañino.
- Se registrarán los incidentes de seguridad que se produzcan y las acciones de tratamiento que se sigan. Esos registros se emplearán para la mejora continua de la seguridad del sistema.

2 ALCANCE

El alcance de este procedimiento aplica a todos aquellos sistemas de información y personal relacionado directamente con SPIKA TECH.

En concreto, este documento formaliza el procedimiento utilizado para la gestión, por parte del personal de SPIKA TECH, de los incidentes de seguridad de la información que afecten o puedan llegar a afectar a la información de esta, y detalla las actividades fundamentales de cada fase:

- **Detección y Reporte del incidente de seguridad.**
- **Análisis y Clasificación del incidente.**
- **Tratamiento del incidente (Contención/Mitigación/Recuperación).**
- **Notificación autoridades e información necesaria a notificar.**
- **Análisis post incidentes y cierre.**

3 DEFINICIONES Y ACRÓNIMOS

Evento de seguridad: ocurrencia identificada de un sistema, servicio o estado de red que indica un posible incumplimiento de la política de seguridad de la información, una falla de los controles o una situación desconocida que puede ser relevante para la seguridad.

Incidente de seguridad: Es un único evento de seguridad de la información inesperado o no deseado, o una serie de ellos, que tiene una probabilidad significativa de comprometer las operaciones de la organización y amenazar la seguridad de la información. Es asimismo un evento donde se incumple de manera consciente o inconsciente la política de seguridad.

Brecha de seguridad de los datos personales: Incidente de seguridad que provoca una violación de la seguridad de los datos personales. Toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos

CCN-CERT: Centro Criptológico Nacional.

LOPDGDD: Ley Orgánica 3/2018, de 5 diciembre de Protección de Datos Personales y garantía de los derechos digitales.

RGPD: Reglamento General de Protección de Datos.

4 ROLES Y RESPONSABILIDADES

4.1 Responsable de SGSI

- Se encarga de revisar el procedimiento y aprobarlo.
- Se encarga de supervisar las actividades relacionadas con la gestión de incidentes de seguridad.

4.2 Usuario de SI de SPIKA TECH

- Informa lo antes posible a través de los servicios de notificación de incidentes, cualquier situación observada que pudiera suponer una incidencia en la organización.
- Colabora en la resolución de incidentes de seguridad y en la realización de acciones preventivas cuando sea necesaria su participación para hacer pruebas o aportar información adicional sobre el incidente

4.3 Personal TI de SPIKA TECH

- Se encarga de recabar y validar la información recibida, realizar una clasificación inicial de la incidencia y asignarla al grupo de soporte que corresponda.

4.4 Responsable del Sistema de Información

- Se encarga de la operación del sistema de información, esta responsabilidad recaerá sobre la persona que ostente el cargo de Responsable de Seguridad de la Información.
- Es el responsable de la gestión inicial de cada incidencia, cuando no sea evidente que se trate de una incidencia de seguridad, mediante la recepción de una situación observada por parte de cualquier usuario o notificación de los equipos de monitorización

4.5 Responsable de la Información y Responsable del Servicio

- Determina los requisitos (de seguridad) de la información tratada.

- Determina las especificaciones de seguridad en el ciclo de vida de los servicios y sistemas, acompañadas de los correspondientes procedimientos de control.

4.6 Responsable de Seguridad de la Información

- Apoyar y supervisar la investigación de los incidentes de seguridad desde su notificación hasta su resolución y participar en la toma de decisiones cuando la criticidad del incidente así lo requiera.

- Coordinar la comunicación con INCIBE en la utilización de servicios de respuesta a incidentes de seguridad.

- Supervisar la elaboración de métricas, conclusiones y propuestas de mejora para la gestión de incidencias en la organización.

- Designar al personal o equipo necesario para la realización de acciones y tareas.

4.7 Responsable del Tratamiento de Datos Personales

- Analizar la peligrosidad e impacto del riesgo de las brechas de seguridad relacionadas con un impacto directo sobre los datos personales, adoptar las decisiones oportunas, para asegurar la protección de los datos personales y la seguridad de la información.

- Adoptar las decisiones para la gestión y contención del incidente, valorando el impacto sobre los datos personales y las personas físicas en su caso, la información y prestación de los servicios.

- Evaluar si el impacto tiene consecuencias sobre la reputación de la organización. Definir la línea de actuación.

5 MODELO PARA LA GESTIÓN DE INCIDENTES

La gestión de incidentes comprende acciones específicas para cada una de las fases del proceso. Este proceso se inicia mucho antes de que ocurra el incidente y finaliza mucho después de que el incidente es mitigado. En esta sección se describen las fases principales del proceso de respuesta a un incidente, a saber:

Figura1. Fases para la gestión de incidentes de Seguridad de la Información y Ciberseguridad

Todo el flujograma de comunicación y gestión de cada una de estas fases se encuentra en el ANEXO 4: Flujograma de comunicación.

5.1 Preparación

5.1.1 Introducción

Es una fase proactiva con el doble objetivo de prevenir la aparición de incidentes y preparar al servicio de coordinación de incidencias que debe recibir por parte de cada uno de los responsables:

- Identificación y valoración de los Sistemas de Información de la organización.
- Definición de avisos y alertas para su difusión sobre la existencia de amenazas y condiciones particulares en los Sistemas de Información de la organización.
- Recopilación de recomendaciones de la aplicación de medidas de protección o identificación ante situaciones excepcionales.

También se contempla con carácter general para todos los usuarios de la organización, la formación y concienciación en buenas prácticas del uso de los recursos TIC y la forma de proceder en caso de que se detecta una situación inusual que pueda representar una amenaza para la seguridad de la información:

Esta fase es fundamental dentro del programa de respuesta a incidentes teniendo en cuenta que incluye las actividades orientadas a suministrar las recomendaciones básicas para prevenir y gestionar adecuadamente los incidentes cuando estos ocurren. Incluyendo herramientas, mecanismos, y procedimientos de detección que alerten al organismo de comportamientos anómalos en sus sistemas y redes.

5.1.2 Fase aplicada a SPIKA TECH

Como parte de la preparación ante incidentes de seguridad de la información y ciberincidentes se establecen varios cauces para la notificación de los mismos.

Dentro de esta etapa se hace uso de herramientas tecnológicas que permiten una adecuada identificación y visibilidad de actividades inusuales dentro de las cuales se destacan las herramientas para la correlación de eventos y herramientas para la monitorización y control sobre la red.

5.2 Detección, análisis e identificación

5.2.1 Introducción

La detección ocurre cuando desde cualquier punto del servicio o desde algún punto de interconexión, se observa alguna actividad anormal o sospechosa. En dicho caso se genera una alerta que puede provenir de:

- Sistemas integrados de monitorización y generación automática de incidencias.
- Personal/Usuario relacionados con algún servicio afectado.
- Administrador o Responsable Técnico del servicio o aplicación.

Es fundamental identificar cuanto antes la amenaza y la peligrosidad potencial para reducir el posible impacto sobre el servicio. Es en esta fase donde se activa el proceso de comunicación mediante los sistemas de notificación de incidencias de la organización al equipo de atención de incidencias de primer nivel, que procede a registrarla junto con toda la información conocida relevante, con el objeto de determinar una clasificación inicial y actuar en consecuencia con la magnitud del incidente. A partir de este momento se documentará todo lo relativo a la incidencia para contribuir al análisis de esta.

Con la información obtenida en el análisis inicial se priorizarán las próximas actividades que se ejecutarán con la debida diligencia para mitigar el posible impacto que pueda tener la incidencia, evitando así que se propague a otros servicios.

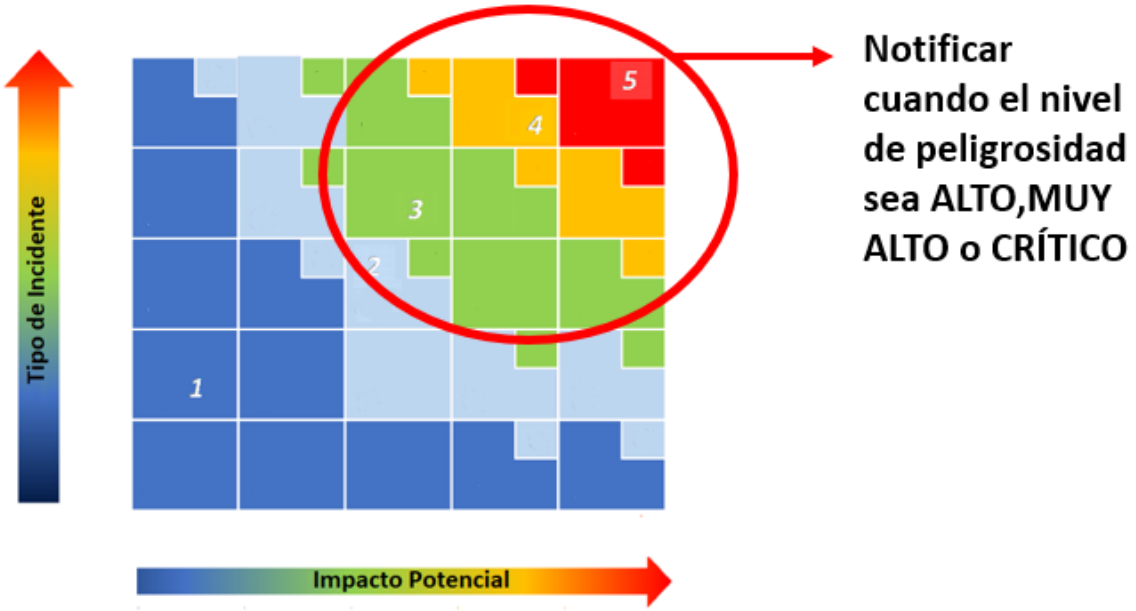
Una vez que el incidente es detectado y verificado deberá ser clasificado antes de ser asignado y notificado, en caso de que sea necesario, conforme a lo establecido en el apartado "6. NOTIFICACIÓN DE LOS INCIDENTES DE SEGURIDAD O CIBERINCIDENTES",. El criterio de referencia utilizado por el CCN-CERT en sus comunicaciones es el de Nivel de Peligrosidad, cuando no sea posible identificar claramente los síntomas del incidente, para realizar una evaluación inicial de su peligrosidad, se asociará a aquel que tenga un Nivel de peligrosidad superior de acuerdo con las características intrínsecas a la tipología de amenaza y su comportamiento.

El impacto potencial de un incidente de seguridad o ciberincidente se determina evaluando las consecuencias que tal incidente tiene en las funciones de la organización, en sus activos o en los individuos afectados.

La peligrosidad de un incidente de seguridad o ciberincidente dado, se asignará a uno de una escala de cinco valores. Esta escala, de menor a mayor peligrosidad, es la mostrada a continuación. **Para su cálculo, deberá tenerse en cuenta el tipo de incidente y el impacto potencial.**

NIVEL	1	2	3	4	5
PELIGROSIDAD	BAJO	MEDIO	ALTO	MUY ALTO	CRITICO

TIPO DE INCIDENTE x IMPACTO POTENCIAL= PELIGROSIDAD



Ver ANEXO 1 TIPOS DE INCIDENTES y ANEXO 2 DETERMINACIÓN DEL NIVEL DE IMPACTO, para más información.

La herramienta empleada para la monitorización y seguimiento de incidentes de seguridad recogerá la tipología de incidente, fecha de inicio, métricas, etc., si bien, para calcular su impacto es necesario que un operario de la Oficina de Seguridad Informática revise su alcance y contenido para verificarlo, y en su caso obtener el nivel de peligrosidad, que en caso de alcanzar el nivel ALTO, MUY ALTO o CRÍTICO, será notificable.

5.2.2 Fase aplicada a SPIKA TECH

Para el caso del **Personal/Usuario** de un sistema de información se reportará mediante correo electrónico aquellos sucesos inesperados o no deseados con posibles consecuencias negativas relacionadas a la seguridad de la información que detecte, una vez recibido el

reporte se genera un primer filtro para descartar y asignar a su correcto responsable, aquellos eventos que no corresponden a un incidente de seguridad y que hacen parte de una solicitud o asistencia relacionada con la operación diaria.

- Correo: incidencias@spikatech.com

Cualquier incidencia puede reportarse mediante correo electrónico incidencias@spikatech.com, aunque las mismas están relacionadas con un phishing, malware, etc.,

El responsable según el tipo de incidencia o notificación a realizar, la información solicitada al usuario será diferente, con el fin de poder clasificar y gestionar la incidencia correctamente.

El análisis inicial, busca recolectar la información suficiente para poder confirmar la clasificación del incidentes, amenazas y posibles vulnerabilidades asociadas, así como el impacto asociado, para su posterior notificación al Responsable de Seguridad, o la persona que este designe, será el encargado de notificar y escalar, de acuerdo con la criticidad establecida.

Para mayor detalle ver **ANEXO 4: Flujograma de comunicación**.

Con el fin de facilitar el contacto para el reporte y gestión de los incidentes de seguridad de la información y ciberseguridad, se establece el **ANEXO 4: Flujograma de comunicación,** mediante el cual se relacionan los datos que permitan la comunicación con cada una de las personas responsables o vinculados a su análisis evaluación o investigación.

5.3 Contención, mitigación y recuperación

5.3.1 Introducción

Es en esta fase cuando se empiezan a poner en marcha las medidas de contención que permitan proteger la seguridad de las personas, proteger la información, minimizar el impacto en los servicios y, en su caso, en los derechos y libertades de las personas físicas.

La contención busca evitar que el incidente se propague y comprometa otros sistemas. Una vez que el incidente ha sido aislado, la organización deberá intentar, en primera instancia, mitigar su impacto, procediendo después a su eliminación de los sistemas afectados y tratando finalmente de recuperar el sistema al modo de funcionamiento normal. La recuperación implica establecer las medidas de control necesarias que permitan minimizar el riesgo de que las amenazas existentes puedan ser materializadas en un futuro.

5.3.2 Fase aplicada a SPIKA TECH

De acuerdo al flujograma establecido en el **ANEXO 4: Flujograma de comunicación,** una vez identificada y clasificada la incidencia se debe realizar una evaluación del tipo de impacto asociado para determinar junto con el/los Responsable(s) del Sistema o Servicios/ Responsables del Tratamiento, si se presenta una deficiencia grave que este afectando la seguridad de los datos personales o aplicaciones y determinar si se requiere alguna acción específica e inmediata del servicio/tratamiento.

De la misma manera se debe evaluar si se dan las condiciones de activación del plan de continuidad del negocio para notificar y escalar al responsable de su gestión aportando la mayor cantidad de información disponible para que se establezca la mejor estrategia de recuperación.

Para aquellos casos de incidentes que puedan afectar a la autenticidad, integridad, trazabilidad, confidencialidad o disponibilidad, se deben generar acciones encaminadas a la recolección y preservación de evidencias de tal forma que se cumpla con la debida diligencia y las cadenas de custodia requeridas en este tipo de casos.

De forma enunciativa, y no limitativa, se recogen algunas acciones que pueden llevarse a cabo durante la gestión de un incidente:

Contención

- Si es posible, se debe impedir el acceso al origen de la divulgación: dominios, puertos, servidores, la fuente o los destinatarios de la divulgación. Dependiendo del vector de ataque, impedir el acceso al origen: dominios, conexiones, equipos informáticos o conexiones remotas, puertos, parches, actualización del software de detección (antivirus, IDS, etc.) bloqueo de tráfico, deshabilitar dispositivos, servidores, etc.
- Suspender las credenciales lógicas y físicas con acceso a información privilegiada. Cambiar todas las contraseñas de usuarios privilegiados o hacer que los usuarios lo hagan de manera segura.
- Hacer una copia del sistema (clonado), hacer una copia del disco duro que contiene el sistema, y luego analizar la copia utilizando herramientas forenses.
- Aislar el sistema utilizado para revelar los datos con el fin de realizar un análisis forense más tarde.
- Si los datos han sido enviados a servidores públicos, solicitar al propietario (o web master) que elimine los datos divulgados.
- Si no es posible eliminar los datos divulgados, proporcionar un análisis completo al departamento correspondiente o a quien ejerza dichas funciones.
- Vigilar la difusión de los documentos/datos filtrados en los diferentes sitios web y redes sociales (Facebook, Twitter, etc.) así como los comentarios y reacciones de los usuarios de Internet.
- Aislar el equipo o desconectar el segmento de red del resto de redes. Esto se puede hacer, en el caso de un dispositivo aislado, desconectando directamente el cable de red, o aislando un segmento de red en una VLAN o similar.
- En el caso de que la infección ocurra en un dispositivo crítico, el tráfico estrictamente necesario puede ser aislado a través de la configuración de un firewall entre este elemento y el resto de la red, permitiendo solo el tráfico estrictamente necesario para el funcionamiento del sistema.
- Si el tipo de incidente ha sido identificado, y se conocen detalles técnicos, como la propagación de malware, el patrón de comportamiento de una denegación de servicio o las características de un intento de intrusión a través de la fuerza bruta es posible aplicar medidas de contención más apropiadas para un conjunto dado de circunstancias. Por ejemplo, el bloqueo de correos electrónicos específicos, el acceso a equipos compartidos, conexiones salientes o cualquier vector de infección de malware a través de políticas y reglas de firewall. De la misma manera, es posible programar reglas de filtrado para las entregas de servicio o intentos de intrusión.

- En el caso de una vulnerabilidad que podría resultar en una intrusión o denegación de servicio, se deben aplicar todos los procedimientos de mitigación recomendados por el fabricante y se deben instalar los parches recomendados.
- Se deberá tener en cuenta si la realización de estas u otras acciones conllevan la suspensión temporal de servicios y sus consecuencias.

Recuperación

- Revisar el proceso de desinfección, basado en firmas, herramientas, nuevas versiones/revisiones de software, etc. y probarlo. Hay que asegurar que el proceso de desinfección funciona adecuadamente sin dañar servicios.
- Comprobar la integridad de todos los datos almacenados en el sistema, mediante un sistema de hashes, por ejemplo, que permita garantizar que los ficheros no han sido modificados, especial atención debe ser tenida con relación a los ficheros ejecutables.
- Revisar la correcta planificación y actualización de los motores y firmas de antivirus.
- Análisis con antivirus de todo el sistema, los discos duros y la memoria.
- Restaurar conexiones y privilegios paulatinamente. Especial acceso restringido paulatino de máquinas remotas o no gestionadas.
- Se debe considerar también si las medidas aplicadas son de carácter temporal o si forman parte de una solución definitiva, y el sistema y/o la información afectada ha vuelto de nuevo de modo efectivo a su estado original.
- Además, debe asegurarse que la misma vulnerabilidad no podrá ser explotada en el futuro, o dicho en otros términos, se deberán de tomar medidas que eviten o eliminen la posibilidad de que un incidente vuelva a producirse. En este sentido, dentro del proceso de mejora continua, será necesario actualizar el plan de riesgos del centro afectado revisando si el análisis de riesgos contemplaba la amenaza que dio lugar a la brecha o incidente de seguridad y, en caso afirmativo, reevaluar las medidas de salvaguarda asociadas a fin de garantizar su efectividad.

De forma paralela y bajo la coordinación por parte de Responsable de SGSI, o la persona que éste designe, se deben activar las notificaciones internas o externas (según el caso), que permitan generar comunicados desde una fuente única, especialmente en las notificaciones externas.

Durante toda la fase de contención, mitigación y recuperación se establecerá una monitorización por parte del equipo de seguridad informática, que evaluará el desarrollo de la incidencia y verificará si necesita la aprobación o ejecución de medidas adicionales para una adecuada gestión y cierre del incidente.

5.4 Actividades posts-incidentes

5.4.1 Introducción

Con los registros recopilados durante la incidencia se procede a realizar un análisis de los pasos realizados, obtención de métricas, conclusiones y propuestas de mejora del proceso, para la gestión de incidencias posteriores y lo más importante, extraer las lecciones aprendidas que permitan mejorar los procesos existentes y generar una base de conocimiento valiosa al nuevo personal que se incorpora a la organización. Una parte importante de esta etapa incluye el actualizar, extender, mejorar u optimizar los procedimientos de resolución de incidentes, basado en las lecciones aprendidas y el análisis del resultado de la atención de incidentes previos.

5.4.2 Fase aplicada a SPIKA TECH

Tras la recuperación de los servicios, se realizará una valoración Post-Incidente donde se extraerá cualquier medida de mejora que permita evitar que la misma incidencia u otra de similares características vuelva a ocurrir.

Para incidentes de seguridad de nivel ALTO, MUY ALTO o CRÍTICO, el Responsable del Servicio y de la Información en colaboración con el Responsable de Seguridad llevarán a cabo el análisis de los incidentes de seguridad con los siguientes objetivos:

- Identificación de las causas que propiciaron la materialización del incidente.
- Identificación de las lecciones aprendidas.
- Identificación de las acciones correctivas que deberán de ser implementadas con el fin de:
  - Reducir o eliminar la probabilidad de la ocurrencia en el futuro del incidente de seguridad de la información.
  - Reducir el impacto del incidente de seguridad de la información en caso de que vuelva a producirse en el futuro.

Ver **ANEXO 4: Flujograma de comunicación** para más información.

Una vez finalizadas todas las tareas que permitan la resolución completa del incidente y/o brecha de seguridad, así como el análisis post-incidente, la persona designada del equipo de seguridad de la información procederá a comunicar el cierre de la incidencia a la persona Responsable de Seguridad, al Responsable del Tratamiento, así como a la persona que lo reportó.

6 NOTIFICACIÓN DE LOS INCIDENTES DE SEGURIDAD O CIBERINCIDENTES.

Los organismos privados están obligados a notificar de forma inmediata aquellos ciberincidentes acaecidos en su infraestructura tecnológica cuyo **nivel de peligrosidad sea ALTO** o superior al INCIBE, que es el CSIRT de referencia para el sector privado.

Deberán notificarse todos los incidentes/ciberincidentes con peligrosidad **ALTO, MUY ALTO o CRÍTICO al INCIBE** en un **plazo máximo de 72h** desde la detección del mismo, el Responsable de Seguridad, o la que este designe, será competente dentro de SPIKA TECH para realizar dicha notificación, y será el punto de contacto para la gestión del incidente de seguridad.

El resto de incidentes/ciberincidentes con peligrosidad o impacto inferior (MEDIA y BAJA) no se notificarán al INCIBE, pero deberán ser clasificados por SPIKA TECH, registrados y archivados para futuras auditorías, siendo responsabilidad del mismo la correcta custodia de la documentación.

Ver **ANEXO 4: Flujograma de comunicación**.

6.1 Notificación de incidentes de seguridad externa

El encargado de notificar los incidentes de seguridad al INCIBE será el Responsable de Seguridad:

- A través del correo electrónico **incidencias@incibe-cert.es**

Todos los incidentes de seguridad, ciber-incidentes o brechas de seguridad, que se determinan como de obligada notificación a las autoridades de control, se remitirán, en tiempo y forma, respetando los tiempos mencionados en la siguiente tabla.

Nivel de peligrosidad	Notificación inicial	Notificación intermedia	Notificación final
CRÍTICO	**Inmediata**	**24 / 48 horas**	**20 días**
MUY ALTO	**Inmediata**	**72 horas**	**40 días**
ALTO	**Inmediata**	**-**	**-**
MEDIO	**-**	**-**	**-**
BAJO	**-**	**-**	**-**

- La notificación inicial es una comunicación consistente en poner en conocimiento y alertar de la existencia de un incidente.

- La notificación intermedia es una comunicación mediante la que se actualizarán los datos disponibles en ese momento relativos al incidente comunicado.

- La notificación final es una comunicación final mediante la que se amplían y confirman los datos definitivos relativos al incidente comunicado.

No obstante, se aportarán todas aquellas notificaciones adicionales intermedias o posteriores que se consideren necesarias.

Toda la información recibida por parte de las autoridades de control se debe direccionar hacia el Responsable de Seguridad o la persona que éste designe, que será el punto de contacto con INCIBE y la persona responsable de coordinar el incidente de seguridad dentro del SPIKA TECH.

En el ANEXO 4 CONTENIDO DE LA COMUNICACIÓN, se indica un cuadro con la información que se puede pedir para poder reportar la incidencia.

6.2 Notificación de incidente de seguridad externa

El Responsable de Seguridad designado junto con el Responsable de RRHH, elaborarán un mensaje para los usuarios de la organización si fuese necesario comunicar el incidente de seguridad. Para ello se seguirán la siguiente jerarquía de vías:

- Correo electrónico corporativo y personal.

7 BRECHAS DE SEGURIDAD (datos personales)

El análisis de las brechas de seguridad tiene un componente tecnológico enfocado a los controles y medidas de seguridad y otro en que es necesario la valoración de los riesgos para los derechos y libertades de las personas. Ambos aspectos implican la participación tanto de las personas Responsables de Seguridad, personas que éste designe, y en su caso, del Delegado de Protección de Datos (DPD) y Responsables del Tratamiento.

7.1 Clasificación Brechas de Seguridad

Una brecha de seguridad se puede clasificar en una o varias de las siguientes categorías:

CLASIFICACIÓN DE LAS BRECHAS DE SEGURIDAD	
Tipo brecha	**Descripción y ejemplos prácticos**
Brecha de confidencialidad	Tiene lugar cuando partes que no están autorizadas, o no tienen un propósito legítimo para acceder a la información, acceden a ella. La severidad de la pérdida de confidencialidad varía según el alcance de la divulgación, es decir, el número potencial y el tipo de partes que pueden haber accedido ilegalmente a la información.
Brecha de integridad	Se produce cuando se altera la información original y la sustitución de datos puede ser perjudicial para el individuo. La situación más grave ocurre cuando existen serias posibilidades de que los datos alterados se hayan utilizado de una manera que pueda dañar al individuo.
Brecha de disponibilidad	Su consecuencia es que no se puede acceder a los datos originales cuando es necesario. Puede ser temporal (los datos son recuperables, pero tomará un periodo de tiempo y esto puede ser perjudicial para el individuo), o permanente (los datos no pueden recuperarse).

7.2 Nivel de riesgo (peligrosidad)

Según el carácter de la brecha de seguridad y los objetivos y prioridades de negocio afectados, se establecerá un riesgo (peligrosidad) de la misma que facilitará la identificación de las acciones a corto plazo que deben tomarse para contener la situación. En el riesgo (peligrosidad) de la brecha se tendrán en cuenta su criticidad, impacto, alcance y daños a la

información, actividad normal y reputación de la organización, pudiendo tomar los siguientes niveles:

MUY ALTO	ALTO	MEDIO	BAJO

Niveles de riesgo (peligrosidad) de una brecha de seguridad

Los criterios de determinación del nivel de riesgo (peligrosidad) de una brecha de seguridad dependerán de los factores indicados en el ANEXO 3 VALORACIÓN DE LAS BRECHAS DE SEGURIDAD.

7.2.1 Notificación brechas de seguridad (datos personales)

El RGPD en su punto 12 del artículo 4, define las brechas de seguridad como *"violación de la seguridad de los datos personales: toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos"*.

La notificación de las brechas de seguridad se prevé, tanto respecto a la autoridad de control (RGPD, art. 33), como al interesado (RGPD, art. 34).

Procede la notificación a la autoridad de control cuando se produzca la (i) destrucción, pérdida o alteración; o (ii) la comunicación o acceso no autorizado, sin que el RGPD especifique número y tipo de afectados, por lo que se deberán notificar las brechas, con independencia del número reducido de datos o no.

El contenido de la notificación comprenderá la naturaleza de la brecha, incluyendo, si es posible categorías y número de afectados, datos del DPD, consecuencias de la violación, medidas adoptadas o en evaluación. El Responsable del Tratamiento documentará la brecha de seguridad en el Registro de brechas de seguridad, con la colaboración del Responsable de Seguridad o la persona que éste designe.

El RGPD prevé la exención de la obligación de notificar cuando el responsable pueda probar, atendiendo al principio de responsabilidad proactiva, la improbabilidad de que la brecha entrañe un riesgo para los derechos y libertades de las personas físicas.

Asimismo, únicamente cuando sea probable que la brecha de seguridad de los datos personales entrañe un alto riesgo para los derechos y libertades de las personas físicas, el Responsable del Tratamiento o DPD comunicará al interesado sin dilación indebida, con un lenguaje claro y sencillo, informándole del suceso y si debe llevar a cabo algún tipo de acción.

Se restringe la obligación de comunicar a los afectados a los supuestos de alto riesgo (Art. 34 RGPD), no siendo obligatorio la comunicación a (i) los supuestos en que existe riesgo (que por el contrario si se debe notificar a la autoridad de control, salvo que sea improbable que constituya un riesgo, art. 33 RGPD); (ii) los datos están cifrados o son ininteligibles mediante otra técnica (imposible el acceso); (iii) el responsable del tratamiento ha adoptado medidas ulteriores que han neutralizado el alto riesgo para los derechos y libertades del interesado (riesgo anulado); (iii) la notificación suponga un esfuerzo desproporcionado, optándose en este caso, por una comunicación pública o una medida semejante por la que se informe de manera igualmente efectiva a los interesados.

De acuerdo con la **valoración de acuerdo con el numeral 7.2 deberán notificarse todas las brechas de seguridad con nivel de riesgo ALTO y MUY ALTO a la Agencia Española**

de Protección de Datos (AEPD), sin dilaciones indebidas, dentro del plazo máximo de 72 horas desde la detección de la misma.

Las notificaciones de brechas de datos personales a la AEPD se deben realizar de forma electrónica, usando el formulario de notificación de brechas de datos personales de la **Sede Electrónica** para garantizar una correcta ejecución de las obligaciones del artículo 33.3 del RGPD.

Por otro lado, en el caso de brechas con nivel de riesgo MUY ALTO, deberán ser comunicadas asimismo a los ciudadanos afectados; esta comunicación se realizará de igual manera por parte de la persona o área designada por el Responsable del Tratamiento.

Cuando la brecha de seguridad de los datos personales se produzca en los sistemas de información utilizados por el encargado del tratamiento de datos para la prestación de los servicios contratados, estos encargados están obligados a notificar al Responsable del Tratamiento, sin dilación indebida, y en cualquier caso antes del plazo máximo de 24 horas hábiles, las brechas de seguridad de los datos personales a su cargo de las que tenga conocimiento, junto con toda la información relevante para la documentación y comunicación de la incidencia. Se debe verificar la cláusula establecida en el contrato de encargado de tratamiento suscrito con el proveedor o colaborador.

El Reglamento General de Protección de Datos reconoce que los responsables no siempre van a disponer de toda la información concerniente a la incidencia de seguridad en el plazo de 72 horas, y que, en ocasiones, será necesario realizar seguimientos de las incidencias para poder obtener la información que se debe comunicar a la AEPD, por todo ello, se permite que se realice una notificación de manera gradual por fases.

Cuando se tenga constancia de que una notificación a la AEPD será de forma gradual, se debe advertir a la Agencia de este hecho informando que se proporcionará más información en cuanto se disponga de ella, explicando los motivos por los que se realiza la notificación por fases.

Si la nueva información obtenida modifica o altera la notificación inicial que se hizo a la Agencia, deberán reflejarse estas diferencias.

En aquellos casos en los que se considere que no es necesario notificar una brecha de seguridad a la autoridad de control o comunicar a los interesados, deberá incluirse en este Registro una explicación motivada de tales decisiones. Asimismo, en el caso de que se exceda el plazo de 72 horas establecido para la notificación a la autoridad de control, deberán registrarse las causas justificadas que han provocado este retraso.

El motivo de tener registradas todas estas especificaciones, reside en que las mismas servirán de justificación frente a la autoridad de control, ante posibles inspecciones en las que podrá verificar el cumplimiento de las distintas obligaciones de comunicación.

8 REFERENCIAS

- ISO 27001:2022:
  - 5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información.
  - 5.28 Recolección de evidencia.

- 5.25 Evaluación y decisión sobre los eventos de seguridad de la información
- 5.26 Respuesta a incidentes de seguridad de la información
- 5.27 Aprender de los incidentes de seguridad de la información o 5.28 Recopilación de evidencias
- 6.8 Notificación de los eventos de Seguridad de la Información

9 ANEXO 1 TIPOS DE INCIDENTES

Este indicador determina la potencial amenaza que supondría la materialización de un incidente en los sistemas de información. Cada tipo de incidente se asocia a alguno de los siguientes niveles de peligrosidad: CRÍTICO, MUY ALTO, ALTO, MEDIO o BAJO.

CRITERIOS DEL NIVEL DE PELIGROSIDAD DE LOS CIBERINCIDENTES		
Nivel	**Clasificación**	**Tipo de incidente**
CRITICO	Otros	APT
		Ciberterrorismo
		Daños informáticos PIC
MUY ALTO	Código dañino	Distribución de malware
		Configuración de malware
	Intento de intrusión	Ataque desconocido
	Intrusión	Robo
	Disponibilidad	Sabotaje
		Interrupciones
ALTO	Contenido abusivo	Pornografía infantil, contenido sexual o violento inadecuado
	Código dañino	Sistema infectado
		Servidor C&C (Mando y Control)
		Malware dominio DGA
	Intento de intrusión	Compromiso de aplicaciones
	Disponibilidad	DoS (Denegación de servicio)
		DDoS (Denegación distribuida de servicio)
	Compromiso de la información	Acceso no autorizado a información
		Modificación no autorizada de información
		Pérdida de datos

	Fraude	Phishing
MEDIO	Contenido abusivo	Discurso de odio
	Obtención de información	Ingeniería Social
	Intento de intrusión	Explotación de vulnerabilidades conocidas
		Intento de acceso con vulneración de credenciales
	Intrusión	Compromiso de cuentas con privilegios
	Fraude	Uso no autorizado de recursos
		Derechos de autor
		Suplantación
	Vulnerable	Criptografía débil
		Amplificador DDoS
		Servicios con acceso potencial no deseado
		Revelación de información
		Sistema vulnerable
BAJO	Contenido abusivo	Spam
	Obtención de información	Escaneo de redes (scanning)
		Análisis de paquetes (sniffing)
	Intrusión	Compromiso de cuenta sin privilegios
	Otros	Otros

10 ANEXO 2 DETERMINACIÓN DEL NIVEL DE IMPACTO DE LOS INCIDENTES

CRITERIOS DE DETERMINACIÓN DEL NIVEL DE IMPACTO DE LOS CIBERINCIDENTES		
Nivel		**Descripción**
CRITICO	Nivel estimado de afectación.	Afecta más de un 75% de los sistemas de la organización.
	Cantidad estimada de usuarios afectados	Más de un 90 % de usuarios han sido afectados
	Servicios afectados	Afecta una infraestructura crítica en su totalidad
	Tiempo estimado de resolución de la incidencia.	Probablemente sea irreparable
	Alcance reputacional	Los daños reputacionales afectan a la imagen de la Unión Europea
MUY ALTO	Nivel estimado de afectación.	Afecta entre un 50 y un 75% de sistemas de la organización.
	Cantidad estimada de usuarios afectados	Han sido afectados entre un 75 y 90% de los usuarios
	Servicios afectados	Afecta un Servicio esencial
	Tiempo estimado de resolución de la incidencia.	Más de 30 días.
	Alcance reputacional	Los daños reputacionales afectan a la imagen del país.
ALTO	Nivel estimado de afectación.	Afecta entre un 20 y un 50 % de los sistemas de la organización
	Cantidad estimada de usuarios afectados	Han sido afectados entre un 10 y 75% de los usuarios
	Servicios afectados	Afecta parte de un servicio esencial
	Tiempo estimado de resolución de la incidencia.	Entre cinco y 30 días
	Alcance reputacional	El incidente trasciende hasta afectar la reputación de terceros a nivel nacional.

MEDIO	Nivel estimado de afectación.	Afecta aproximadamente menos del 20% de los sistemas de la organización.
	Cantidad estimada de usuarios afectados	Menos de un 10% de los usuarios han sido afectados
	Servicios afectados	Afecta a un servicio no esencial
	Tiempo estimado de resolución de la incidencia.	Entre uno y cinco días
	Alcance reputacional	El incidente llega a ser conocido en los medios de comunicación.
BAJO	Nivel estimado de afectación.	Se desconoce el alcance de los sistemas de información afectados
	Cantidad estimada de usuarios afectados	No se tiene una estimación de usuarios afectados.
	Servicios afectados	Sólo afecta a un grupo de usuarios, no a un servicio.
	Tiempo estimado de resolución de la incidencia.	Menos de un día
	Alcance reputacional	El incidente sólo es conocido internamente, no tiene eco mediático

11 ANEXO 3 VALORACIÓN BRECHA DE SEGURIDAD (datos personales)

Los criterios de determinación del nivel de riesgo (peligrosidad) de una brecha de seguridad dependerán de los factores indicados a continuación:

RIESGO (PELIGROSIDAD) DE UNA BRECHA DE SEGURIDAD	
Categoría o nivel de criticidad	**Descripción**
CRÍTICO	Afecta a datos valiosos, gran volumen y en poco tiempo
MUY ALTO	Cuando dispone de capacidad para afectar a información valiosa, en cantidad apreciable
ALTO	Cuando dispone de capacidad para afectar a información valiosa
MEDIO	Cuando dispone de capacidad para afectar a un volumen apreciable de información
BAJO	Escasa o nula capacidad para afectar a un volumen apreciable de información
Naturaleza, sensibilidad y categorías de los datos personales afectados	
Datos de escaso riesgo: datos de contacto, de educación, familiares, profesionales, biográficos	
Datos de comportamiento: localización, tráfico, hábitos y preferencias	
Datos financieros: transacciones, posiciones, ingresos, cuentas, facturas	
Datos sensibles: de salud, biométricos, datos relativos a la vida sexual, etc.	
Datos legibles/ilegibles	Datos protegidos mediante algún sistema de pseudonimización (por ejemplo, cifrado o hash)
Volumen de datos personales	Expresados en cantidad (registros, ficheros, documentos) y/o en periodos de tiempo (una semana, un año, etc.)
Facilidad de identificación de individuos	Facilidad con la que se puede deducir la identidad de los individuos a partir de los datos involucrados en la brecha
Severidad de las consecuencias para los individuos	
BAJA	Las personas no se verán afectadas o pueden encontrar algunos inconvenientes que superarán sin ningún problema (tiempo de reingreso de información, molestias, irritaciones, etc.).

MEDIA	Las personas pueden encontrar inconvenientes importantes, que podrán superar a pesar de algunas dificultades (costos adicionales, denegación de acceso a servicios comerciales, miedo, falta de comprensión, estrés, dolencias físicas menores, etc.).
ALTA	Las personas pueden enfrentar consecuencias importantes, que deberían poder superar, aunque con serias dificultades (malversación de fondos, listas negras de los bancos, daños a la propiedad, pérdida de empleo, citación judicial, empeoramiento de la salud, etc.).
MUY ALTA	Las personas pueden enfrentar consecuencias significativas, o incluso irreversibles, que no pueden superar (exclusión o marginación social, dificultades financieras tales como deudas considerables o incapacidad para trabajar, dolencias psicológicas o físicas a largo plazo, muerte, etc.).
Características especiales de los individuos	Si afectan a individuos con características especiales o con necesidades especiales.
Número de individuos afectados	Dentro de una escala determinada, por ejemplo, más de 100 individuos.
Características especiales del responsable del tratamiento (de la entidad en sí)	En base a la actividad de la entidad.
El perfil de los usuarios afectados	Su posición en la estructura organizativa de la entidad y, en su consecuencia, sus privilegios de acceso a información sensible o confidencial.
El número y tipología de los sistemas afectados	
El nivel de impacto que la brecha puede tener en la organización	Desde los puntos de vista de la protección de la información, la prestación de los Servicios, la conformidad legal y/o la imagen pública. Va a estar relacionado con la categoría o criticidad de los servicios y personas afectados
BAJO	perjuicio limitado
MEDIO	perjuicio grave
ALTO	perjuicio muy grave

Los requerimientos legales y regulatorios	Notificación de la brecha a la autoridad de control y cualquier otra obligación de notificación, comunicación a Fuerzas y Cuerpos de Seguridad del Estado en caso de delito.

Valoración del alcance de una brecha de seguridad

12 ANEXO 4 CONTENIDO COMUNICACIÓN (informativo)

La comunicación se realizará siempre por escrito mediante el uso de correo electrónico o sistema proporcionado por el INCIBE haciendo uso de la información que se posea en ese momento, más o menos la información solicitada será esta:

Qué notificar	Descripción
Asunto	Frase que describa de forma general el incidente. Este campo lo heredarán todas las notificaciones asociadas al incidente.
OSE/PSD	Denominación del operador de servicios esenciales o proveedor de servicios digitales que notifica.
Sector estratégico	Transportes: aviación, carreteras, marítimo, etc.
Fecha y hora del incidente	Indicar con la mayor precisión posible cuándo ha ocurrido el ciberincidente.
Fecha y hora de detección del incidente	Indicar con la mayor precisión posible cuándo se ha detectado el ciberincidente.
Descripción	Describir con detalle lo sucedido.
Recursos tecnológicos afectados	Indicar la información técnica sobre el número y tipo de activos afectados por el ciberincidente, incluyendo direcciones IP, sistemas operativos, aplicaciones, versiones…
Origen del incidente	Indicar la causa del incidente si se conoce. Apertura de un fichero sospechoso, conexión de un dispositivo USB, acceso a una página web maliciosa, etc.
Taxonomía (clasificación)	Posible clasificación y tipo de ciberincidente en función de la taxonomía descrita.
Nivel de Peligrosidad	Especificar el nivel de peligrosidad asignado a la amenaza. Consultar Tabla 4. Criterios de determinación del nivel de peligrosidad de un ciberincidente.
Nivel de Impacto	Especificar el nivel de impacto asignado al incidente. Consultar Tabla 5. Criterios de determinación del nivel de impacto de un ciberincidente.
Impacto transfronterizo	Indicar si el incidente tiene impacto transfronterizo en algún Estado miembro de la Unión Europea. Especificar.

Plan de acción y contramedidas	Actuaciones realizadas hasta el momento en relación al ciberincidente. Indicar el Plan de acción seguido junto con las contramedidas implantadas.
Afectación	Indicar si el afectado es una empresa o un particular y las afectaciones de acuerdo a los criterios indicados en la Tabla 5. Criterios de determinación del nivel de impacto de un ciberincidente.
Medios necesarios para la resolución (J-P)	Capacidad empleada en la resolución del incidente en Jornadas-Persona.
Impacto económico estimado (Si se conoce)	Costes asociados al incidente, tanto de carácter directo como indirecto.
Extensión geográfica (Si se conoce)	Local, autonómico, nacional, supranacional, etc.
Daños reputacionales. (Si se conocen)	Afectación a la imagen corporativa del operador.
Adjuntos	Indicar la relación de documentos adjuntos que se aportan para ayudar a conocer la causa del problema o a su resolución (capturas de pantalla, ficheros de registro de información, correos electrónicos, etc.)
Regulación afectada	ENS / RGPD / NIS / PIC / Otros
Se requiere actuación de FFCCSE	Si / No